INCIDENT EVIDENCE WALKTHROUGH

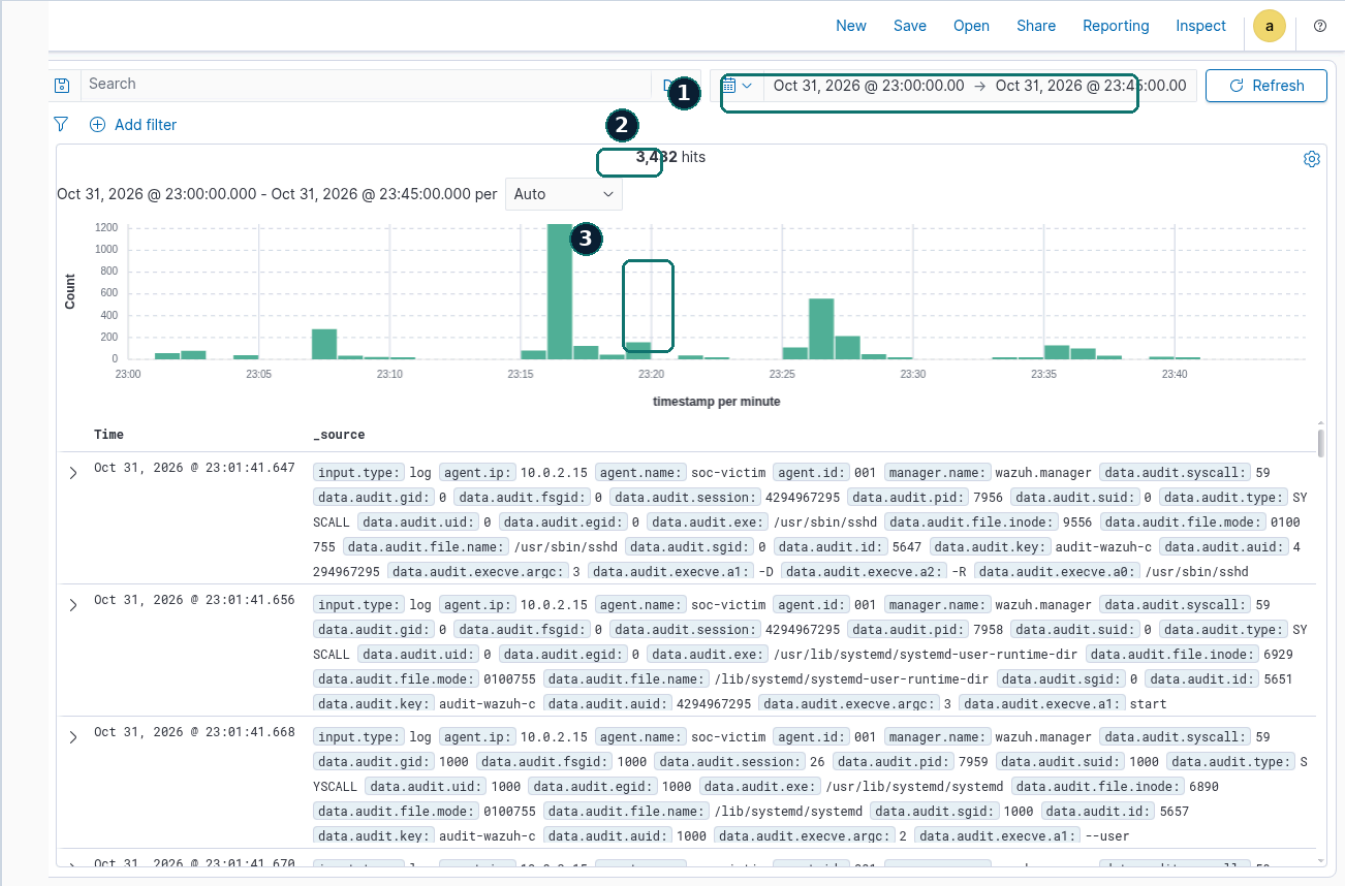
Outbound SYN sweep

INC-005 · Medium severity · 31 October 2026 · soc-victim

200	154	50/5 s	0
ports scanned	scan alerts	threshold	follow-on events

1. Start with the hour

Forty five minutes of network and host alerts. The scan is a dense burst at 23:26, then nothing.



1. Full window in UTC, empty query.
2. The burst at 23:26 is the scan.
3. The flat line after 23:27 is the absence of follow-on activity.

WHAT TO LOOK FOR IN THE LOGS

Density

Many alerts in a few seconds from one source.

Direction

Outbound from the victim to the gateway.

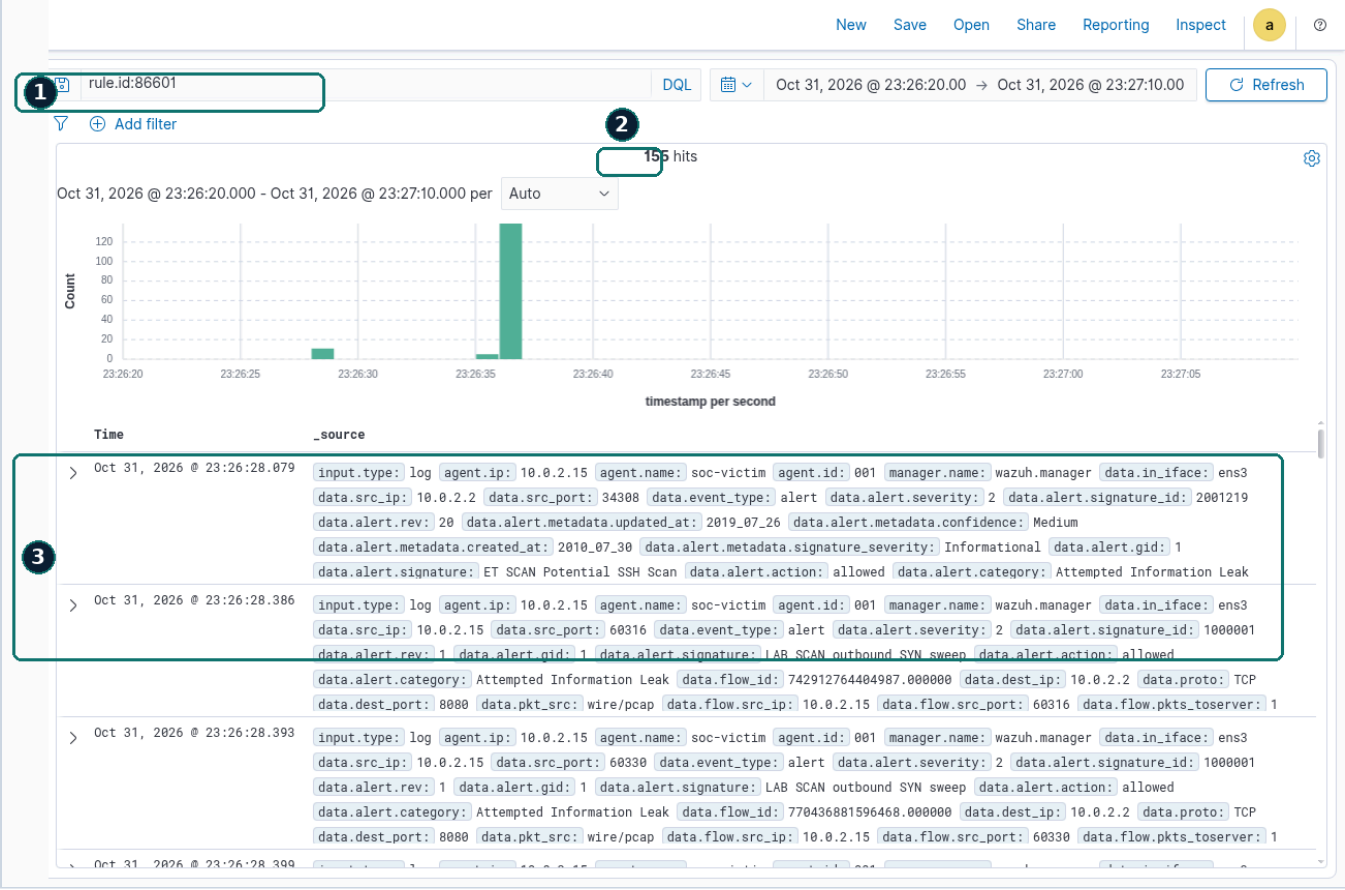
Aftermath

No authentication or process activity follows.

> Volume without follow-on activity is reconnaissance, not compromise.

2. Stock wrapper, noisy signature

Wazuh rule 86601 wraps every Suricata alert. In this window it fires 155 times, and almost all of them are the local scan signature.



1. Query on the stock wrapper rule.
2. 155 hits, more than any other rule in the window.
3. The rows show signature and destination port, but the wrapper alone does not rank them.

WHAT TO LOOK FOR IN THE LOGS

Wrapper rule

86601 does not distinguish a scan from an SSH false positive.

Read the signature

data.alert.signature is the field that matters.

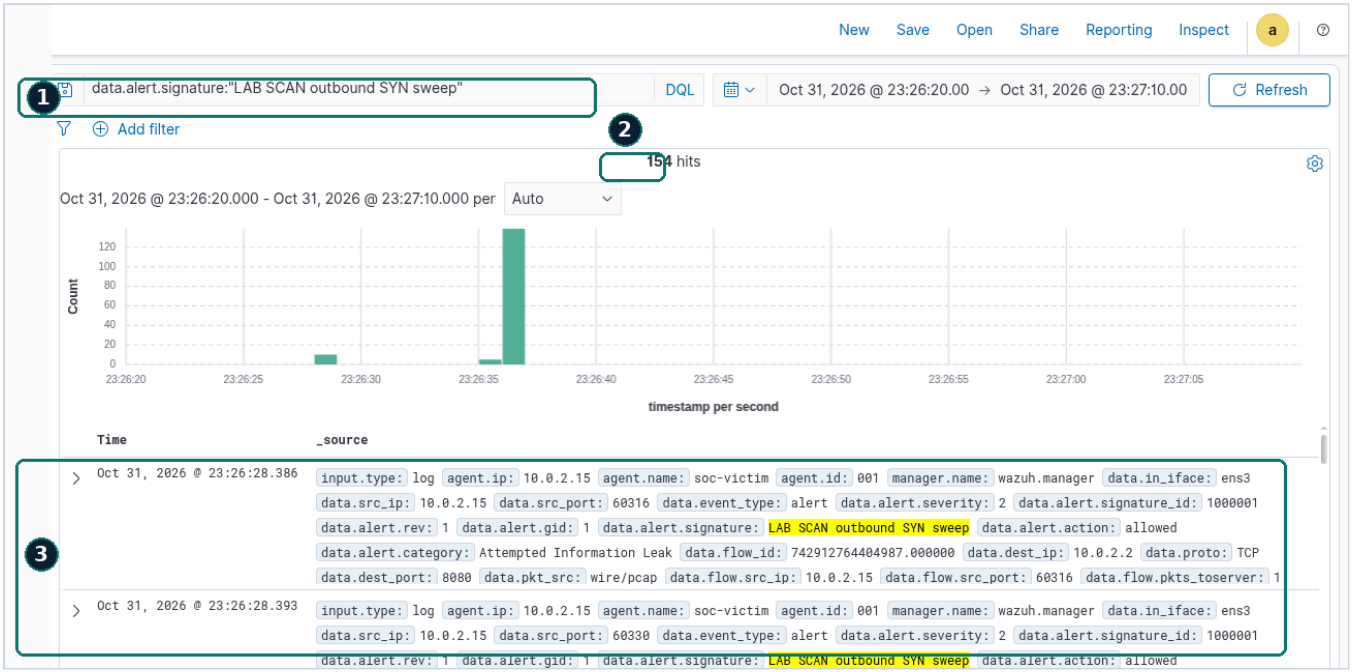
Ports

Many destinations in a short window is the scan pattern.

> A generic wrapper is only as useful as the signature behind it. Filter on the signature next.

3. Apply the local signature

The local Suricata rule, sid 1000001, names the behaviour: an outbound SYN sweep above 50 packets in 5 seconds.



1. Query on the local signature.
2. 154 hits, all from the same signature.
3. The rule and its threshold are documented in the INC-005 rules paper.

WHAT TO LOOK FOR IN THE LOGS

Threshold

50 SYNs in 5 seconds from one source.

Direction

$HOME_NET to $EXTERNAL_NET, outbound.

No payload

SYN only, so this is discovery, not exploitation.

> The threshold is the tuning decision. Too low catches health checks, too high misses slow scans.

4. The scan alerts

A sample of the exported alerts, signature and destination port per line.

soc-lab, INC-005, Suricata alerts, UTC

```
$ jq -r '.[] | select(.rule.id=="86601")
      | "\(.timestamp[11:19])  \(.data.alert.signature)  \(.data.dest_ip):\(.data.dest_port)"'
\
      docs/evidence/INC-005-alerts.json | head -9
23:26:28  ET SCAN Potential SSH Scan  10.0.2.15:22
23:26:28  LAB SCAN outbound SYN sweep  10.0.2.2:8080
23:26:28  LAB SCAN outbound SYN sweep  10.0.2.2:8080
23:26:28  LAB SCAN outbound SYN sweep  10.0.2.2:8080
23:26:28  LAB SCAN outbound SYN sweep  10.0.2.2:8080
23:26:28  LAB SCAN outbound SYN sweep  10.0.2.2:8080
23:26:28  LAB SCAN outbound SYN sweep  10.0.2.2:8080
23:26:28  LAB SCAN outbound SYN sweep  10.0.2.2:8080
23:26:28  LAB SCAN outbound SYN sweep  10.0.2.2:8080
```

1. One line is a stock ET SCAN SSH signature, triggered by routine SSH and unrelated to this scan.
2. The remaining rows carry the local scan signature, each with a different destination port.

ALERT MIX

RULE	ALERTS	WHAT IT ADDS
86601	155	Suricata wrapper alerts
LAB SCAN	154	Local signature, outbound sweep
ET SCAN SSH	1	Stock signature on normal SSH

> Do not count wrapper alerts as findings. Count signatures.

5. Signature mix

Two signatures share the same wrapper rule. Only one describes this incident.

soc-lab, INC-005, signature mix

```
$ jq -r '.[] | select(.rule.id=="86601") | .data.alert.signature' \
    docs/evidence/INC-005-alerts.json | sort | uniq -c
      1 ET SCAN Potential SSH Scan
    154 LAB SCAN outbound SYN sweep
```

1. 154 alerts for the local outbound scan signature.
2. One alert for a stock SSH scan signature, which is a false positive.

WHAT TO LOOK FOR IN THE LOGS

Local signature

LAB SCAN outbound SYN sweep.

Stock signature

ET SCAN Potential SSH Scan, triggered by routine SSH.

Ratio

The wrapper overstates the finding by one row, not by much here, but the principle holds.

> Name the signature in the ticket. A wrapper rule ID alone is not evidence.

6. Scan output and threshold

The nmap output confirms 200 ports, and the false-positive test shows where the threshold sits.

soc-lab, INC-005, scan output

```
$ cat docs/evidence/INC-005-scan.txt
# Nmap 7.93 scan initiated Sat Oct 31 23:27:10 2026 as: nmap -sS --top-ports 200 --min-rate 500
-oN /tmp/nmap-inc005.txt 10.0.2.2
Nmap scan report for 10.0.2.2
Host is up (0.00035s latency).
Not shown: 196 closed tcp ports (reset)
PORT     STATE SERVICE
443/tcp  open  https
```

1. The scan completed in 0.15 seconds against the gateway.
2. The rule fired once per packet group, not once per port.

WHAT TO LOOK FOR IN THE LOGS

Ports

200 top ports, SYN only.

Rate

--min-rate 500, which crosses the 50/5 rule.

Follow-on

No login, process, or egress activity after 23:27.

> Reconnaissance alone is Medium. If authentication followed, it becomes High.

7. How to capture this evidence

1. **Start broad**
   Forty five minutes around the burst.
2. **Stock wrapper**
   All Suricata alerts.

```
rule.id:86601
```

3. **Local signature**
   Isolate the scan signature.

```
data.alert.signature:"LAB SCAN outbound SYN sweep"
```

4. **Save the rule**
   The signature, threshold, and revision.

```
cat /var/lib/suricata/rules/local.rules
```

5. **Record the threshold test**
   Legitimate bursts below and above 50 per 5 seconds.

```
cat docs/evidence/INC-005-fp.txt
```

> A scan is low impact by itself. The ticket must show what did not happen after it.

8. What to look for

One source, many destinations
The shape of a sweep.

SYN only
No completed handshakes, so discovery.

No follow-on
No auth failures, no process execution, no egress.

Threshold context
Was the rate above the tuning boundary?

Direction
Outbound from the victim is more serious than inbound noise.

COMMON PITFALLS

Wrapper noise
86601 fires for every signature, including SSH false positives.

Threshold is a trade
Lower catches more and pages more. Document the boundary.

Scan is not compromise
Do not raise severity without follow-on evidence.

Verdict: Medium severity, no compromise. Reconnaissance only, threshold documented, no follow-on authentication or execution.